Limitaciones y cosas no verificadas

No se presenta como hecho lo que no se probó.

Depende de credenciales o ambientes reales (NO probado contra el servicio real)

Integración	Estado	Qué falta
ClaveÚnica	Implementado (OIDC) y probado con simulación (`/dev/login`, `ClaveUnicaService` sin prueba HTTP real).	`client_id/secret`, URL de retorno registrada; validar formato de `userinfo`.
FirmaGob v2	`HttpFirmaClient` probado con `Http::fake` (JWT HS256, OTP, checksum, 5 MB, sin redirecciones).	Credenciales y ambiente `test`; **validar URLs de prod/test, nombres de claims y de la respuesta (A VALIDAR)**; verificar firma atendida con OTP real; lógica de reintentos ante 429.
Casilla Única / Notificador	Modo `outbox` (operativo, sin envío real) y panel de gestión; modo `api` genérico (token fijo u OAuth2) **no basado en el contrato oficial**: la guía de integración no fue accesible desde el entorno.	Contrato y credenciales (A VALIDAR).
Gmail API (cuenta de servicio)	Transporte probado con cliente HTTP simulado: JWT RS256, único scope, `sub` =buzón, éxito, fallo, reintento, cuota, inyección de cabeceras.	JSON real, delegación de dominio autorizada, envío real.
LLM	Probado con respuestas simuladas; apagado por defecto.	Clave de API y revisión de la política de uso de IA del municipio.

Integración	Estado	Qué falta
Códigos CPAT/OAE	El seed usa **ejemplos** con el formato `PA-UNI00002-00001`.	Cargar los códigos reales del catálogo CPAT.

Reglas de firma asumidas

Ver `DECISIONES.md` #1, #2 y #5 (ágil=1 / clásico=2 por defecto; primera firma del decreto alcaldicio por alcalde o delegado; número tras la última firma).

Técnicas

- **MySQL/MariaDB no disponible** en el entorno de construcción: las pruebas corren sobre **SQLite**. `01_schema.sql` se genera desde las migraciones con gramática MySQL y se verifica sintaxis/estructura por pruebas, pero **no se ejecutó en un servidor MySQL real**: importarlo en un entorno de pruebas antes de producción. La concurrencia del correlativo se probó con procesos paralelos en SQLite; el mismo patrón (UPDATE atómico + bloqueo InnoDB) es válido en MySQL pero **no se probó en MySQL**.
- **Triggers / GRANT por tabla:** pueden no estar disponibles en hosting compartido (cPanel asigna privilegios a nivel de BD completa). Sin ellos, la inmutabilidad de `audit_log` se apoya en el modelo y en la **detección** por cadena HMAC; un atacante con acceso directo a MySQL puede alterar y recalcular la cadena **solo si conoce `AUDIT_HMAC_KEY`** (que no está en la BD).
- **PDF/A y firma PAdES de la copia pública:** la copia pública y los PDF de versión se generan con Dompdf (no PDF/A). Con FirmaGob real el PDF firmado está disponible solo como documento de trabajo; la copia pública incluye la hoja de certificado pero no fusiona la firma PAdES (A VALIDAR si la norma exige copia autorizada con firma visible).
- **Antivirus:** no hay ClamAV; la validación de subidas es estructural. PDF con contenido activo legítimo (formularios con JS) serán rechazados.
- **Archivos en memoria:** se cifra/descifra en memoria (límite 10 MB por archivo, 5 MB para firmar con FirmaGob); `memory_limit` ≥ 256 MB recomendado.
- **TinyMCE:** requiere `style-src 'unsafe-inline'`. Idioma `es` desde `tinymce-i18n` (licencia A VALIDAR).
- **Accesibilidad:** se verificó con revisión manual básica (foco visible, etiquetas, "saltar al contenido", contraste del color primario sobre blanco). **No** se ejecutó una auditoría WCAG automatizada completa (axe/lighthouse) ni pruebas con lector de pantalla.
- **Larastan:** ver `DECISIONES.md` #21.

- **Concurrencia de sesiones, bloqueo de cuentas, rotación automática de claves y reporte automático al CSIRT:** no implementados.
- **Interoperabilidad (PISEE), integración con SIAPER/otros sistemas:** no implementadas.
- **Sesiones `__Host-`:** la cookie requiere HTTPS; en `http://localhost` Chromium la acepta (verificado), otros navegadores pueden no hacerlo.
- El **panel de incidentes** registra hitos pero no envía reportes; plazos legales A VALIDAR.

Interoperabilidad (PISEE, Codificador, DocDigital) — no verificada contra los servicios reales

- **Sin acceso a las especificaciones oficiales** (los hosts de Gobierno Digital no eran alcanzables desde el entorno de construcción; solo se pudieron consultar resúmenes de búsqueda). Los contratos no se inventaron: son configurables y están marcados **A VALIDAR** en el código (`HttpDocDigitalClient`, `PiseeService`, `CodificadorService::sincronizar`) y en `docs/NORMATIVA.md` §11–13.

- **PISEE:** solo consumidor, con mTLS y una cabecera de identificación configurable. Si el nodo exige otro mecanismo (firma de mensajes, cabeceras adicionales, SOAP, etc.), hay que adaptar `PiseeService::llamar()`. Requiere adhesión a los T&C PISEE y un nodo instalado en la municipalidad. No se publican servicios propios como proveedor.

- **Codificador:** catálogo local, cargable por **CSV** (el «Listado de códigos de Instituciones» oficial, 6.452 filas, se importa tal cual y se **verificó completo** en SQLite y MariaDB) o por la **API oficial** documentada (`docs/interop/codificador-api.md`). La API **no se probó contra el servicio real** (el entorno de desarrollo no llega al host); su forma de respuesta se tomó del documento y de la guía de Postman. Quedan por validar: la doble URL (`codificacion.digital.gob.cl/api/v1/…` del documento y `codificador.digital.gob.cl/codigos/…` de la guía), el `/v1` repetido, el id de la codificación «Instituciones» (se supone 1: coincide con el CSV) y la ausencia de paginación (la primera sincronización trae todo en una respuesta de hasta 20 MB). El listado oficial trae **2 filas incompletas** (`PE-undefined-…` sin descripción) que se omiten y se informan.

- **DocDigital:** el cliente sigue la **especificación OpenAPI v3.2.514** entregada (`docs/interop/docdigital-openapi-3.2.514.json`), pero **no se probó contra el servicio**

real (la red de desarrollo no llega a DocDigital): pruébelo en **DemoDoc**. Requiere Administrador Principal e interlocutor ante la SGD. La **URL de producción** (`DOCDIGITAL_URL_PROD`, por defecto `https://api-doc.digital.gob.cl/api`, el «Generated server url» del Swagger) **no figura en el archivo OpenAPI**: A VALIDAR con Gobierno Digital. Solo se envían PDF con FEA real (`pdf_firmado_*`, devuelto por FirmaGob); la numeración propia de DocDigital no se integra con el correlativo del SGD. No se implementa visación/firma dentro de DocDigital ni acuse de recepción/lectura (solo el ID de envío).

- La sincronización lista `GET /documentos/recibidos?notificado=false` y descarga el archivo principal de cada documento (`/documentos/{id}/archivo/descargar`) y sus **anexos** (`?archivo_id=`). Hasta 200 documentos por sincronización (4 páginas de 50). Cada recibido crea su expediente en la unidad receptora (`DOCDIGITAL_UNIDAD_RECEPCION`).

- **Recepción (expediente por comunicación entrante):** usa el acuse (`PUT /documentos/recibidos/{id}/acusorecibo`) y la devolución (`…/devolver`) de la especificación; no se probaron contra DocDigital real; en `outbox` es una referencia manual. No se interpreta el contenido de la comunicación (sin clasificación automática ni plazos de respuesta). El identificador único usa el código de institución del Codificador (A VALIDAR el esquema oficial).

- **Google Drive (unidad compartida):** probado solo contra un **Drive simulado** (`tests/Support/FakeDrive.php`) que reproduce el contrato de la API v3 (`supportsAllDrives`, carpetas, md5). **No se ha probado contra Google real**: valide con *Probar conexión* y una migración piloto. Dependencia: disponibilidad/cuotas de Drive; las escrituras fallan cerradas.

- **Cifrado + Drive:** si se pierden las claves de `sgd_secrets`, los archivos en Drive no se pueden recuperar. El respaldo de claves es responsabilidad de la institución.

- **Firmas en la copia pública:** el sello visual (estilo/posición) se estampa en la copia pública. **No** reemplaza la firma electrónica avanzada: el PDF firmado por FirmaGob conserva su propia representación y sus coordenadas en el proveedor son **A VALIDAR**.

- **Secretos en BD:** los secretos ingresados desde el panel se guardan cifrados con `APP_KEY` (`SGD_API_SECRETOS_EN_BD=1`, por defecto); quien obtenga la base **y** el `.env` (APP_KEY) los descifra. Si se rota `APP_KEY` hay que volver a ingresarlos. Con `SGD_API_SECRETOS_EN_BD=0` solo valen los de `.env`.

- **Roles personalizados:** el techo por rol base acota los permisos de un **rol** (los de cada **persona** se pueden personalizar sin ese límite, salvo los reservados al sistema); no existen permisos por expediente ni por unidad (la visibilidad por unidad sigue las reglas de acceso existentes).

- **Usuarios conectados:** se basa en la tabla de sesiones (actividad dentro del tiempo de vida de sesión); no detecta usuarios con la pestaña abierta pero inactiva más allá de ese plazo.

- **Log de aplicación:** la redacción es por patrones (RUN, correos, tokens, rutas); puede dejar pasar datos con formatos no previstos. Revíselo antes de compartirlo fuera de la institución.

- **Logo y accesibilidad:** el sistema exige texto alternativo y valida contraste de colores, pero no puede juzgar si el contenido del logo es legible.

- **Editor (TinyMCE 7, GPL):** se omiten por seguridad los plugins de medios (`media`, iframes), `codesample` y emoticonos. El sanitizador del servidor es la autoridad: lo que el editor muestre y el servidor elimine (p. ej. un estilo no admitido) desaparece al guardar. Fuentes: solo las de la lista (Arial, Verdana, Tahoma, Georgia, Times, Courier, Roboto); en PDF Dompdf las aproxima con las fuentes que dispone.

- **Imágenes en PDF:** se incrustan con Dompdf; imágenes muy grandes o muchas imágenes aumentan memoria y tamaño del PDF. Las imágenes subidas no se pueden borrar (solo dejar de usarlas); no hay depuración de huérfanas.

- **Visibilidad de formatos:** se basa en la unidad del usuario (una unidad por persona); no hay jerarquía de unidades (una dirección no hereda a sus departamentos).

- **PDF de ejemplo de formatos:** usa datos ficticios y no tiene validez; no incluye firmas ni folio.

- **Reconocimiento de firmas:** solo PDF (PAdES/PKCS#7 desprendida y CAdES); otros formatos figuran «No aplica». No se revisa revocación (CRL/OCSP) ni sellos de tiempo cualificados; firmas con RSA-PSS o formatos heredados (`adbe.x509.rsa_sha1`) quedan «no verificable». Sin `SGD_FIRMA_CA_BUNDLE` la confianza del emisor **no se afirma**; la lista de CA de prestadores acreditados en Chile y qué política de certificado equivale a firma «avanzada» (Ley 19.799) son **A VALIDAR**. Probado con certificados autofirmados de prueba, no con firmas reales de

FirmaGob/Acepta/E-Sign. Con `FIRMAGOB_MODE=mock` el PDF «firmado» no trae firma criptográfica y se informa como tal.

- **Panel de recursos:** en hosting compartido (CloudLinux/LVE) la CPU y la RAM leídas de `/proc` son las del **equipo**, no las de su plan, salvo que el hosting exponga cgroups; lo no legible se muestra «sin dato». La CPU se mide en una ventana de ~250 ms (instantánea, no promedio). El histórico depende de que el cron de cPanel ejecute `schedule:run` cada minuto.

- **Inventario de componentes:** lee archivos instalados; no consulta bases de vulnerabilidades (use `composer audit`). Las versiones del front-end se leen de los encabezados de cada archivo (si un proveedor cambia el formato, se muestra «—»). La detección de CDN es estática (vistas, CSS, JS propios y activos): no ve recursos que un script construya dinámicamente; la CSP del navegador es la barrera efectiva.

- **Ambiente de pruebas con contraseña:** `SGD_AMBIENTE=pruebas` evita ClaveÚnica y entra como el usuario real con ese RUN (incluido administrador y alcalde), sin segundo factor. Es una herramienta de **revisión temporal**: vence sola (máx. 45 días), se bloquea por RUN, y jamás debe convivir con datos reales. El procedimiento de instalación se verificó en MariaDB 10.11 (no en el MySQL del hosting): pruebe la migración en su servidor y revise el registro si algo falla.

- **Pentest:** la revisión (`docs/PENTEST.md`) la hizo el equipo con asistencia de IA; no sustituye a un pentest externo ni cubre la infraestructura del hosting (WAF, aislamiento entre cuentas, TLS del servidor).

- **Mapa de conexiones:** la geolocalización es **por país y aproximada** (base «IP to Country Lite», datos a octubre de 2026): VPN, proxy, redes móviles y CDN pueden aparecer en otro país; algunas direcciones se atribuyen a países vecinos o por registro. El mapa no muestra ciudades. Las conexiones **salientes** solo incluyen las que hace la aplicación con el cliente HTTP de Laravel (ClaveÚnica, FirmaGob, DocDigital, PISEE, Codificador, Google, IA); no ve el tráfico del hosting ni del navegador. La IP del visitante es la que informa el servidor: detrás de proxy/CDN requiere `TRUSTED_PROXIES`. El conteo agrega una escritura por petición (bajo costo; se puede desactivar con `SGD_REGISTRAR_CONEXIONES=false`). Las IP son datos personales (Ley 19.628/21.719): definir retención y base legal con el encargado de datos.

- **Código malicioso:** ninguna defensa elimina el riesgo de **contenido engañoso** (p. ej., un borrador de IA con texto falso o un enlace https a un sitio de *phishing* dentro de un documento): el sistema neutraliza código ejecutable, advierte y exige revisión humana, pero no valida la veracidad. Los enlaces `https://` se permiten en los documentos.

Accesibilidad

Ver `docs/ACCESIBILIDAD.md`: pruebas automáticas (PHPUnit y axe-core en navegador real, 0 violaciones en las páginas auditadas) y revisión de teclado, **pero sin auditoría manual con lectores de pantalla ni certificación externa**; los PDF generados no son PDF/UA; el canal de contacto y su plazo de respuesta (`SGD_ACCESIBILIDAD_CONTACTO`) deben definirse por la Municipalidad.

Gestión de trámites por dirección

- La **unidad del usuario** define el alcance; el sistema no valida que sea la correcta (dato administrativo). Un usuario sin unidad no puede crear trámites.
- Un trámite tiene **una dirección propietaria**; la co-gestión entre direcciones se hace mediante el administrador (que sí puede asignar varias direcciones *responsables* de la bandeja).
- Los textos son **texto plano** (sin formato enriquecido ni enlaces activos) por seguridad; los adjuntos del ciudadano usan los mismos tipos y límites ya existentes (PDF/JPG/PNG/TIFF, 10 MB).
- El catálogo público no tiene categorías temáticas (solo búsqueda y filtro por dirección), costos, horarios ni sucursales, y el trámite elegido solo se recuerda si se parte desde el botón de la ficha (no si se escribe la URL del formulario sin haber ingresado). No hay aprobación en dos pasos (quien tiene `tramites.publicar` publica directamente), ni expiración automática de trámites.
- No se verifica que el contenido sea *veraz* (ver riesgo residual en `docs/PENTEST.md` §9.5).
- **Sin extensión `sodium`:** se usa la alternativa con OpenSSL (misma salida que libsodium). Requiere OpenSSL ≥ 1.1 con `chacha20-poly1305`; el rendimiento es similar. La interoperabilidad se verificó contra libsodium en las pruebas, pero la alternativa no pasó por una auditoría criptográfica independiente.
- **Capturas de los manuales:** las imágenes de `public/assets/manual` corresponden al diseño anterior; el texto de los manuales está actualizado, pero las capturas deben regenerarse. El inicio no tiene los bloques «Noticias», «Cumpleaños» ni «Alertas normativas» de la intranet de referencia (no hay fuente de datos para ellos).

Archivo municipal (microformas)

- **No sustituye la certificación legal.** El acta se adjunta como PDF; el sistema solo informa si detecta firma electrónica y **no** valida quién firmó ni su competencia. La normativa aplicable está en `docs/NORMATIVA.md` §7 (**A VALIDAR**).
- La disposición de originales (eliminación o transferencia) **solo se registra**; el sistema no ejecuta nada sobre documentos físicos.
- Una microforma certificada **no se puede anular ni modificar**; una corrección requiere registrar una nueva microforma (o intervención técnica documentada en base de datos).
- Los archivos maestros tienen el límite de 10 MB por archivo (PDF, JPG, PNG, TIFF) y 300 por microforma; no se procesan rollos de microfilm ni se hace OCR. No hay catálogo de series, tabla de retención ni préstamo de soportes físicos.
- El acceso es por permisos (no por unidad): quien tiene `archivo.ver` ve todas las microformas.

Panel DocDigital

- **Alcance del cliente DocDigital v3:** implementa `POST /oauth/token`, `POST /documentos/firmado/ingresar`, `GET /documentos/recibidos`, acuse, devolución, descarga del archivo principal y consulta de entidades y tipos. **No** implementa: documentos «borrador» (endpoint deprecado), atributos adicionales, anexos de tipo `url` (enlaces), consulta de estado/historial de un documento, búsqueda de usuarios ni layouts de firma. La especificación **no tiene un campo «responde a»**: el vínculo entre una respuesta y el documento recibido se guarda solo en este sistema (`responde_a_id`). El **id de entidad** de cada institución destinataria debe asociarse a mano (Administración › Instituciones) o coincidir exactamente por nombre.
- «Probar conexión» obtiene el token y consulta la ruta de recibidos solo para leer el código HTTP; un resultado correcto no garantiza que el formato de los documentos coincida con lo esperado.
- DocDigital exige PDF con firma electrónica avanzada y un Administrador Principal registrado; el sistema no lo verifica contra DocDigital.
- Las credenciales entregadas por la institución son de **producción**: no las use desde el ambiente de pruebas con envíos reales; use DemoDoc si existe.

Casilla Única e inicio dual

- **Contrato sin validar:** la guía https://wikiguias.digital.gob.cl/es/Manuales/integracion-casillaunica no fue accesible desde el entorno de construcción. La URL, la autenticación (token u

OAuth2) y el JSON de envío/confirmación son una propuesta mínima; hasta validarlos, mantenga el modo **outbox** (evidencia manual). «Probar conexión» solo obtiene el token: no envía notificaciones.
- El inicio dual asume que ingresar como funcionario(a) con ClaveÚnica acredita también su identidad de vecino(a) (mismo RUN). En el acceso de **pruebas** (usuario y contraseña) la identidad la declara la cuenta de prueba.
- El conflicto de interés se controla por **RUN**: no detecta parentesco ni solicitudes presentadas por terceros en nombre del funcionario.

Progreso y pasos

- La barra de carga de vistas es **aproximada** (no mide bytes de la página): avanza por fases y se completa al terminar la carga. La barra de la **subida de archivos sí es real** (bytes enviados al servidor); la fase posterior de verificación y cifrado en el servidor no tiene porcentaje (se muestra como paso en curso).
- Tras una subida, la URL puede quedar en la de la acción si el servidor responde sin redirección (p. ej. error 419); recargar vuelve a la vista anterior.
- Los pasos se aplican a la solicitud del vecino, el trámite y la microforma; los demás formularios (breves) se envían de una vez.

Roles Autoridad y OIRS, plazos y tableros

- **Plazos A VALIDAR:** la Ley 19.880 cuenta días **hábiles** y existen feriados y suspensiones de plazo; el sistema cuenta días corridos por defecto (o lunes a viernes con `SGD_PLAZOS_HABILES=true`) y **no modela feriados**. El criterio de suspensión mientras el solicitante responde una devolución es una decisión de diseño pendiente de validar con la asesoría jurídica.
- La **etapa** es una derivación del estado de la solicitud, el expediente y sus documentos; no distingue la sub-etapa dentro de la visación (solo quién debe visar o firmar a continuación).
- Los tableros calculan sobre **todas** las solicitudes en el servidor: con decenas de miles de registros convendrá agregar tablas de resumen.
- Autoridad y OIRS ven **nombre y RUN** del solicitante (necesario para la consulta); cada acceso queda auditado con el RUN enmascarado. No hay exportación a CSV/Excel en esta versión.
- Las instalaciones existentes reciben los roles al ejecutar las migraciones; las **cuentas de prueba** se crean con `pruebas:seguimiento` (el instalador lo hace al actualizar un sitio de

pruebas). Si ya existía un rol personalizado con clave `autoridad` u `oirs`, la migración no lo reemplaza: renómbrelo antes.

Rol Transparencia (activa y pasiva)

- **Plazos y reglas A VALIDAR:** 20 días hábiles de respuesta, prórroga de 10 días hábiles, derivación por incompetencia y suspensión por antecedentes son criterios de la Ley 20.285 tal como se entienden hoy; el sistema **no** modela la notificación y oposición de terceros, los plazos de amparo ante el Consejo para la Transparencia ni los plazos de derivación (2 días) como alertas automáticas. Valide con la asesoría jurídica.
- **Feriados:** no vienen precargados; mientras no se registren, los días hábiles cuentan de lunes a viernes.
- El **catálogo de transparencia activa** es referencial; la publicación en el portal de transparencia es **externa**: el sistema solo registra que se publicó (fecha y enlace), no publica ni verifica el enlace.
- La respuesta de una dirección a un requerimiento es **texto**; los documentos que deban entregarse se agregan al expediente por Transparencia. No hay recordatorios por correo de requerimientos próximos a vencer (se ven en el tablero).
- La derivación a otro órgano **no envía** el oficio: registra que se envió por DocDigital, oficio o correo y cierra el expediente; notifique al solicitante con el documento de derivación.
- Los reportes son un instrumento interno: **no reemplazan** el formato de reporte que exija el Consejo para la Transparencia.

Portal del vecino

- **Diseño de referencia no verificado:** `tramites.santodomingo.cl` y ChileAtiende no fueron accesibles desde el entorno de construcción (política de red). El portal replica el patrón habitual de estos sitios (buscador destacado, más solicitados, exploración por dirección, ficha con requisitos), no su apariencia exacta. Si desea una réplica más fiel, adjunte capturas de las pantallas.
- La búsqueda es textual simple (nombre, descripción e instrucciones): no corrige errores de tipeo ni usa sinónimos. «Más solicitados» y «Más buscados» salen del número de solicitudes por trámite, no de las búsquedas.
- No hay categorías temáticas (p. ej. «vivienda», «salud») ni costos/arancel del trámite: no existen como datos; se explora por dirección municipal.

Feriados, plantillas, restringidos y anuncios

- **Feriados:** no vienen cargados; hasta que se registren, los días administrativos se cuentan de lunes a viernes. La regla de días administrativos y las prórrogas deben validarse con la Ley 19.880 y las instrucciones internas (**A VALIDAR**). El sistema no distingue feriados regionales por comuna: se registran los que apliquen a la comuna.
- **Plantillas de ejemplo:** su texto es referencial (no es asesoría jurídica). Las iniciales de la cadena se calculan desde nombres y apellidos; si dos personas tienen las mismas iniciales no se desambiguan.
- **Restringidos:** la restricción oculta el contenido en el sistema (vistas, descargas, exportaciones, índices y consulta pública), pero **no cifra de forma distinta** los archivos ya almacenados (todos están cifrados en el repositorio). Quien está autorizado puede descargar y compartir el archivo fuera del sistema: la protección posterior depende de las políticas internas. La clasificación de datos personales/sensibles la decide la persona que restringe; el sistema no detecta datos personales automáticamente. Ley 19.628 / 21.719: **A VALIDAR** con el encargado de protección de datos.
- **Bitácora de accesos:** solo registra accesos hechos a través del sistema; no cubre accesos directos al servidor o a la base de datos.
- **Anuncios:** el tamaño real de un video lo limita `upload_max_filesize`/`post_max_size` de PHP (en cPanel suele ser bajo: se ajusta en *MultiPHP INI Editor*). No se transcodifican ni se generan subtítulos: la accesibilidad del video depende de quien lo publica (descripción obligatoria; subtítulos y audiodescripción **no** se generan). Las imágenes GIF/SVG no se admiten.

Respuesta final y avisos por movimiento

- **Casilla Única:** el contrato del aviso (campos `asunto` y `mensaje`) y del envío de documentos es **A VALIDAR**; mientras la conexión esté en modo outbox, cada notificación y aviso queda pendiente hasta registrar el acuse a mano. El correo (Gmail API) es real, pero su evidencia es de **envío**, no de lectura ni de recepción.
- **Volumen en outbox:** cada movimiento genera un aviso por registrar; con mucho volumen conviene activar el modo API o desactivar los avisos de movimiento (`SGD_AVISOS_MOVIMIENTOS=false`) y dejar solo el correo.
- La respuesta final exige el expediente **cerrado**; si se reabre, se instruye de nuevo. Los movimientos anteriores a esta versión no existen (el historial muestra solo el ingreso).

- La entrega física se acredita con un acta de texto (quién recibe, fecha y hora): no hay firma manuscrita digitalizada.
- Las solicitudes sin solicitante ciudadano (comunicaciones recibidas por DocDigital) se responden por DocDigital, no por este flujo.

Asociar expedientes, decreto de pago y egreso

- **Alcance de la búsqueda:** solo se encuentran expedientes que la persona ya puede ver (su dirección o participación). Para reutilizar un proceso de **otra dirección** hay que ser derivado(a) al expediente o pedir que se lo deriven: no existe una consulta transversal (decisión de protección de datos; ampliarla es una decisión institucional).
- **Copias:** lo incorporado es una **copia** (no se sincroniza con el original); si el original cambia después, la copia conserva la huella del momento. Los documentos del flujo (HTML) se copian como su PDF vigente.
- **Decreto de pago:** el contenido jurídico de la plantilla de ejemplo (vistos, considerandos, resolutivos) es **referencial**; el decreto y el egreso no reemplazan el sistema contable municipal: **no** se integra con el presupuesto, el devengado ni el banco (la imputación, la factura y la referencia del pago son texto informado). La disponibilidad presupuestaria no se verifica.
- **Egreso:** el valor legal de un comprobante de egreso con **firma electrónica simple** es **A VALIDAR** con Control, Jurídica y la normativa contable (Ley 19.799; normativa de la Contraloría). Si la institución exige firma avanzada, configure al firmante como «avanzada» (lo exige el sistema).
- **Firma simple:** acredita la voluntad de una persona autenticada en el sistema; no usa certificado. La reautenticación se aproxima con «ingreso en los últimos 30 minutos».
- **Montos:** solo pesos chilenos enteros; no hay multimoneda ni retenciones, impuestos o descuentos.
- **Decreto cargado:** su firma se reconoce, pero la validez de una firma externa no se verifica contra una autoridad certificadora (ver «Reconocimiento de firma electrónica en archivos»).

Tablero de pagos y consulta de proveedores

- La consulta pública solo encuentra decretos con **RUT, número y fecha de factura** registrados; si Finanzas no los ingresó o los digitó distinto (p. ej. otro formato de número), el proveedor verá «sin información» aunque el pago exista. La fecha de la factura debe coincidir exactamente.

- El estado que ve el proveedor refleja el **sistema municipal** (decreto y egreso), no el banco: «Pagada» significa que existe un egreso firmado; el abono efectivo en su cuenta depende del banco.
- La consulta pública es un servicio sin autenticación: aunque exige tres datos y está limitada por tasa, quien conozca los tres datos de una factura ajena puede consultarla. No muestra cuentas bancarias ni datos personales; si la institución exige más garantías (clave del proveedor, ClaveÚnica de empresa), es una decisión posterior.
- El plazo de 30 días (Ley 21.131) se calcula en **días corridos desde la fecha de la factura** (no desde su recepción conforme): referencial, **A VALIDAR** con Jurídica y Finanzas. Sin fecha de factura se usa la fecha del decreto.
- El tablero no distingue facturas con pago retenido por reclamo, multas o retenciones; no hay multimoneda.

ClaveÚnica en la consulta de proveedores

- **Persona, no empresa:** ClaveÚnica acredita la identidad de una persona natural; **no acredita que sea representante o dependiente de la empresa** cuyo RUT ingresa. El sistema no consulta poderes ni el SII. La barrera sigue siendo conocer los tres datos de la factura; la identificación solo agrega **trazabilidad** (queda registrado el RUN de quien consultó) y un freno por persona. Si la municipalidad exige verificar la relación con la empresa (Clave Tributaria, mandatos, registro de proveedores), es una integración futura (**A VALIDAR**).
- Un proveedor extranjero o sin ClaveÚnica no puede consultar por esta vía: debe preguntar en la Dirección de Administración y Finanzas.

Panel de Alcaldía

- Las **firmas delegadas** (cuando firma un delegado vigente) aparecen en el panel de quien firma y en «quién tiene hoy los documentos»; el alcalde no ve un listado aparte de lo que firmaron sus delegados.
- Los montos y proveedores de los pagos son visibles para el alcalde (`decretopago.ver`); si la institución prefiere solo totales, se le puede quitar ese permiso en el rol.
- El panel se calcula al abrirlo (instantánea de ese momento): no hay histórico ni alertas por correo.

Firma y visación por lote

- **OTP:** el comportamiento de la FirmaGob real con un mismo código para varios documentos es **A VALIDAR**. El simulador acepta el mismo OTP en todo el lote; el servicio real podría exigir uno por documento (el lote se detiene y se repite con un código nuevo) o ofrecer firma masiva propia (no integrada).
- El lote firma documentos **sin abrirlos**: la casilla «revisé los documentos» es una declaración; la lista muestra título, tipo y expediente, y cada documento tiene su enlace para revisarlo.
- Cada firma de un lote es una transacción independiente (no hay «todo o nada»): si algo falla a la mitad, lo anterior queda firmado.
- Máximo 25 documentos por lote por defecto (configurable hasta 100); con más pendientes se repite.

Administración: archivos, 2FA, áreas, codificación

- **Normas técnicas:** los Decretos 7, 8, 9, 10, 11 y 12 se revisaron en su texto oficial y la matriz por artículo está en `docs/NORMAS_TECNICAS.md` (generada) y en *Administración › Cumplimiento normativo*. **Sigue pendiente:** las **guías técnicas** (entre ellas las de seguridad del Decreto 7: diagnóstico, controles y formato) que cada norma ordena dictar (nombres exactos de metadatos, formatos, contratos de API: A VALIDAR) y la **API del Codificador**. **Brechas conocidas:** el sistema no reemplaza el análisis de riesgos, la clasificación de activos de información ni el plan de recuperación ante desastres que exige el Decreto 7 (son del municipio; el sistema solo registra la política, los responsables y el diagnóstico); tampoco no incluye un *nodo de interoperabilidad* (Decreto 12) y su módulo PISEE termina el **31-12-2026**; no integra Clave Tributaria ni control de poderes de apoderados o personas jurídicas (Decretos 9 y 10); la hora se almacena con la hora de Chile (se muestra y exporta también en UTC); el comprobante no lleva firma electrónica avanzada institucional; el ingreso alternativo con usuario y contraseña del directorio requiere autorización previa de SEGPRES (Decreto 9, art. 3) o desactivarse.
- La sincronización con el Codificador usa ahora la API oficial documentada (decisión 127); su forma de respuesta se tomó del documento, no de pruebas reales.
- **Segundo factor:** TOTP estándar. No hay SMS ni llave física (WebAuthn). Si un administrador pierde su teléfono y sus códigos de respaldo, otro administrador debe restablecerle el factor (queda en auditoría); si fuera el único administrador, se recupera por consola (`php artisan tinker` o SQL) con acceso al servidor.
- **Pesos máximos:** el límite real también depende de PHP (`upload_max_filesize`, `post_max_size`) y del hosting; el panel lo muestra pero **no puede cambiarlo** (en cPanel: «Select PHP Version › Options»).

- **Formatos ofimáticos:** se rechazan macros y objetos incrustados y se valida la estructura, pero **no hay antivirus** ni análisis de contenido de documentos (enlaces externos, fórmulas de planilla). Se descargan, no se muestran en el navegador. Un CSV abierto en una planilla puede ejecutar fórmulas: advertido en el panel.
- **Diferencias entre versiones de archivos:** solo se calculan para texto (líneas), PDF (páginas aproximadas) y datos generales (tamaño, nombre, formato). Para imágenes y documentos ofimáticos **no se compara el contenido** y el historial lo dice. Un cambio en un PDF que no altere páginas ni tamaño se registra, pero no se describe.
- **Visor en modal:** depende de que el navegador muestre PDF dentro de un marco (Chrome, Edge y Firefox lo hacen; algunos navegadores móviles lo reemplazan por una descarga). «Abrir en una pestaña nueva» y «Descargar» siempre están. TIFF y ofimática no se previsualizan.
- **Historial de documentos anteriores a esta versión:** conservan sus versiones, pero las visaciones y firmas previas al registro de eventos no se reconstruyen (solo la edición).
- **Áreas:** organizan, no restringen. No hay todavía separación de correlativos, plantillas ni informes por área.

Botón ClaveÚnica

- *(Superado)* El botón oficial ya está instalado (kit entregado por Gobierno Digital); vea «ClaveÚnica: botón y certificación» más abajo.

Datos simulados y paso a producción

- El simulador no envía correos ni notificaciones reales; el despacho de la respuesta final depende de la Casilla Única y de Gmail configurados (si no lo están, la respuesta queda «instruida»).
- **Irreversible:** el paso a producción no puede deshacerse desde el panel; quien quiera conservar los datos de prueba debe respaldar antes (base de datos y carpeta de archivos). Los archivos cifrados se borran del repositorio; en una **unidad de Google Drive** se piden a la API (si falla alguno se informa el conteo).
- El borrado cubre las tablas conocidas hoy (una prueba obliga a clasificar las nuevas). Datos fuera de la base y del repositorio (correos ya enviados, registros del servidor web, respaldos) no se tocan.
- Tras el paso, `SGD_AMBIENTE` del `.env` puede seguir diciendo `pruebas`: manda el estado de la base. Se recomienda corregir el `.env` a `produccion` en la misma ventana de mantención.

Tiempos de respuesta y dashboard de DocDigital

- El **tiempo de respuesta** mide hasta el **cierre del expediente**, no hasta que el vecino recibe la notificación final. Las solicitudes devueltas al vecino cuentan el tiempo de espera del vecino (no se descuenta la suspensión). Si una dirección nunca cierra sus expedientes, no aparece en el indicador. Solo se consideran los últimos 12 meses.
- Las solicitudes cuyo expediente no tiene dirección se agrupan como «Sin dirección»; las direcciones sin área, como «Sin área asignada».
- DocDigital: los tiempos de **acuse** y de **respuesta** se calculan con las fechas registradas en el sistema (recepción/sincronización, acuse y creación del envío), no con las de DocDigital. En modo Outbox dependen de que el personal registre los folios a tiempo.

Anexos de DocDigital

- **Enviar:** se adjuntan archivos del propio expediente (hasta `DOCDIGITAL_MAX_ANEXOS`, 10 por defecto; máx. 50 MB c/u, límite de la especificación). Se envía la **versión vigente** de cada archivo; los comprobantes de ingreso no se anexan; un archivo restringido solo lo anexa quien está autorizado. El contenido viaja en base64 dentro de una sola petición: muchos anexos grandes pueden superar el tiempo o la memoria del hosting compartido (el envío queda «fallido» y se reintenta).
- **Recibir:** cada anexo pasa por el mismo control que cualquier archivo cargado: solo se guardan los **formatos habilitados por el administrador** (PDF, imágenes y, si se activan, ofimáticos/TXT/CSV), por contenido y sin macros ni código. Lo que no cumple **no se guarda** y queda registrado con el motivo (se ve en el expediente) y en la auditoría: **el municipio no tiene esos archivos** y debe pedirlos por DocDigital si los necesita. Los anexos de tipo enlace (`url`) no se descargan: el sistema nunca visita direcciones que vengan en la respuesta.
- Los anexos recibidos se guardan como archivos **reservados y sensibles** del expediente (ámbito propio `dd_anexo`), cifrados; no se versionan ni se entregan al solicitante salvo que se agreguen a una respuesta de forma explícita.
- La especificación no permite saber **cuántos anexos tiene** un documento sin listarlo completo; el máximo recibido por comunicación es el mismo `DOCDIGITAL_MAX_ANEXOS`.

Lo que mostró el informe de pruebas de DocDigital (DemoDoc, 31-03-2026)

- **Despacho humano:** un documento cargado por la API queda «pendiente de despacho» hasta que la **Oficina de Partes lo despache en DocDigital**; el SGD no puede despacharlo. Hasta entonces el destinatario no lo ve. Se muestra el estado real, pero **no se pudo confirmar** si `POST /documentos/firmado/ingresar` despacha por sí mismo en el ambiente real (la especificación dice «cargar y despachar»).
- **Acuse y devolución** solo funcionan sobre documentos **ya despachados** (`OPS_RESUELTO_ENVIADO`) y **pendientes de acuse**: en otros estados DocDigital responde 400 con un texto. La **devolución exige un permiso** del usuario de la integración (403 si no lo tiene): pídalo a Gobierno Digital.
- **Tiempos de espera (504):** las consultas sin paginación fallan en DocDigital; el cliente siempre pagina (50 por página, 4 páginas por sincronización).
- **Identificadores de entidad** que informó el DemoDoc: «Municipalidad de Santo Domingo» aparece con id **284** (DOCDIGITAL_ENTIDAD_ID, A VALIDAR en producción: pueden ser distintos).
- El informe señala que el instructivo «Pruebas requeridas en DemoDoc» quedó **obsoleto** respecto de la API actual: este cliente sigue el OpenAPI v3.2.514 entregado, no ese instructivo.

Evidencias y producción de DocDigital

- El registro de evidencias existe para armar el documento de certificación; **no reemplaza las capturas de pantalla de DemoDoc** que también se piden, que debe tomar una persona.
- El JSON de **producción** que se registre contiene materia, descripción, folio y nombres de archivo reales (datos institucionales): se guarda en la base, solo lo ve quien gestiona DocDigital, vence a las 24 h y puede borrarse. Úselo preferentemente en DemoDoc.
- El manual de integración (v1.0, 24-01-2025) y la especificación 3.2.7 difieren en `entidadDestinataria` (consulta vs. cuerpo): se envía en ambos; **A VALIDAR** en DemoDoc. El PDF «Pruebas requeridas» escribe `POST` para acuse y devolución; manual y especificación dicen `PUT` (se usa `PUT`).
- La habilitación en **producción exige certificación de la Secretaría de Gobierno Digital** (formulario https://digital.gob.cl/incidencia con el documento «Certificación de Integraciones para API DocDigital», que **no se recibió ni se revisó**). Tener credenciales de producción que obtienen token no equivale a estar certificado.
- Con modo `prod` el cron `docdigital:sincronizar` (cada 10 minutos) **importa documentos reales** a la base; en un ambiente de pruebas eso mezcla datos reales con los de prueba. Nada se acusa ni devuelve solo.
- Nada de esto se probó contra DemoDoc ni producción reales; las pruebas usan respuestas simuladas.

ClaveÚnica: botón y certificación

- El botón es el del kit oficial entregado; **no se comparó con Figma ni con los lineamientos** (no se recibieron): hágalo antes de certificar.
- El cierre de sesión de ClaveÚnica y la Logout URI se implementaron según el manual 6.5, pero **no se probaron contra el servicio real** (A VALIDAR en sandbox). Sin la Logout URI registrada, ClaveÚnica no redirige de vuelta.
- Los endpoints se mantienen en `config/sgd.php`; el servicio real no es accesible desde el entorno de desarrollo, por lo que las pruebas usan respuestas simuladas.

Carga de claves JSON desde el panel

- La clave queda como **archivo en el servidor** (600, fuera del sitio web), igual que si se hubiera subido por el administrador de archivos: quien tenga acceso al servidor o a un respaldo del directorio puede leerla. No se cifra aparte porque los clientes de Google la leen del disco.
- Al reemplazar la clave de Drive se descarta el token en caché; la clave anterior **no** se revoca en Google (hágalo en Google Cloud).
- Solo se valida la forma de la clave, no que Google la acepte: use «Probar conexión» después de cargarla.

Configuración por pantalla

- «Validar configuración» de ClaveÚnica y FirmaGob solo revisa datos y formato; **no** inicia sesión ni firma (no se puede sin el servicio real). La prueba real de DocDigital sí hace consultas de solo lectura; el correo de prueba **envía un correo** al destino indicado.
- No hay todavía «firma de prueba» con el certificado real ni firma **desatendida** (la integración de FirmaGob es atendida, con OTP del firmante).
- Los datos para Cerofilas (contactos, nombre de la aplicación) son informativos: no se envían a Gobierno Digital.
- ClaveÚnica sandbox/QA solo acepta los RUN de prueba del manual; no sirve para ciudadanos reales.

Superadministrador

- Concentra visibilidad sobre todo el contenido (salvo lo **restringido**): se recomienda asignarlo a muy pocas personas y retirarlo (`sgd:superadmin RUN --quitar`) cuando termine la etapa de pruebas. Toda concesión y retiro queda en la auditoría.
- «Ver todas las vistas» no significa operar por otros: firmar, visar o derivar sigue exigiendo ser el firmante o pertenecer a la unidad. Algunas pantallas personales (p. ej. «Mis firmas») se abren vacías.

Directorio de funcionarios (sistemas_usuarios)

- **Seguridad de la base externa:** la tabla `sistemas_users` tiene una columna `password` (hasta 40 caracteres) que parece guardar **contraseñas en texto plano**, además de `pass` (hash). Ahora el ingreso por usuario lee el hash `pass` (nunca `password`): la columna `password` debería eliminarse o rotarse, y la conexión debe usar un usuario **solo de lectura** limitado a esa tabla.
- El cargo especial (alcalde, secretario(a), tesorería…), la habilitación de firma y la pertenencia a áreas **no** vienen del directorio: se asignan en Administración → Usuarios. La unidad se toma de la «dirección» por nombre exacto (sin distinguir mayúsculas); si no existe se crea.
- El estado se evalúa al ingresar: una baja en el directorio rige desde el siguiente ingreso (las sesiones abiertas no se cortan hasta entonces; se cierran las del usuario dado de baja que el sistema detecte).
- Si un RUN figura más de una vez, se usa la primera fila habilitada y vigente. No se sincronizan las áreas ni el jefe/director de la base.
- No probado contra su base real (solo con una tabla simulada de igual estructura).

Ingreso con usuario y contraseña (directorio)

- Depende de que la columna `pass` de `sistemas_users` tenga hashes bcrypt (`$2y$…`). Si una cuenta tiene solo `password` (texto plano) o `pass` vacío, **no puede ingresar por esta vía** (ClaveÚnica sí). No se hace «migración» de claves en texto plano.
- Sin segundo factor para funcionarios (solo la administración lo exige, y no entra por esta vía). La seguridad de la contraseña es la de la base institucional; el sistema no la cambia ni permite recuperarla.
- Quien ingresa así no tiene identidad de vecino(a) acreditada: para trámites propios como vecino(a) debe ingresar con ClaveÚnica. La política de Gobierno Digital recomienda ClaveÚnica como medio único para personas naturales; esta vía es solo para funcionarios.
- No probado contra su base real (solo con una tabla simulada de igual estructura).

Asistente de IA con proveedores gratuitos

- No se probó contra ningún proveedor real (el entorno de desarrollo no tiene acceso). Formatos implementados según la documentación pública de cada uno: Gemini `generateContent` (cabecera `x-goog-api-key`), y `chat/completions` con `Bearer` para Qwen, OpenRouter, Groq, Mistral y compatibles. Los nombres de modelo sugeridos son **A VALIDAR**.
- Los niveles gratuitos suelen permitir que el proveedor use lo enviado para mejorar sus modelos y tienen cuotas bajas. El sistema quita RUN, correos y teléfonos, pero no puede detectar otra información reservada: no usar la IA con documentos reservados.

Formulario de solicitud

- La vista previa de PDF depende del visor del navegador del usuario (algunos teléfonos solo descargan el PDF); los TIF no se pueden mostrar. «Tomar fotografía» usa el atributo `capture` de HTML: en teléfonos abre la cámara, en computadores el selector de archivos. Probado con un navegador Chromium de escritorio; **no** se probó en teléfonos reales.
- El texto del consentimiento reproduce la cláusula tipo del Título VIII del Decreto N° 2590; si el DPO modifica la redacción hay que actualizar `resources/views/ciudadano/nueva.blade.php` y `ayuda/privacidad.blade.php` (el resumen de privacidad no reemplaza al decreto).

Directorio, organigrama, manuales y recorrido

- La importación del directorio no se probó contra la base real (solo contra una base de prueba con la misma estructura de columnas); «Probar con un RUN» y `directorio:consultar` ayudan a diagnosticar.
- Los nombres de departamentos y unidades se toman tal como vienen del directorio (se normalizan espacios y mayúsculas para no duplicar); si el directorio los escribe distinto en cada fila se crearán variantes.
- Un funcionario creado manualmente (no por el directorio) no se actualiza automáticamente con la importación.
- El recorrido guiado y los manuales por perfil se probaron con un navegador Chromium de escritorio, no con lectores de pantalla reales ni teléfonos.
- No se pudo reproducir ni identificar qué dato del formulario activó el bloqueo de Wordfence; la solución es de configuración del hosting (ver decisión 141).

Varios roles y permisos individuales

- Las pantallas que adaptan su contenido al «rol principal» (por ejemplo el tablero de inicio) siguen mostrando la vista de ese rol; los permisos, el menú y el acceso a las funciones sí suman los de todos los roles.
- Quien tiene roles adicionales de operación puede operar expedientes de su unidad como cualquier funcionario; las reglas de unidad y de contenido restringido no cambian.
- No se probó con un directorio real de usuarios; las reglas están cubiertas por pruebas automáticas.

Gestión de comunicaciones recibidas

- El «estado de gestión» y los estados de las derivaciones son internos del sistema: **no** se informan a DocDigital (la API documentada solo permite acusar recibo y devolver).
- No hay avisos por correo a la persona derivada: lo ve en su bandeja y en el expediente.
- **Directorio de DocDigital:** el contrato de `GET /usuarios/` no entrega los roles de cada persona, por eso se consultan por tipo solo para la entidad propia; los roles de personas de otras entidades no se conocen. La carga completa de todo el Estado puede tardar varias ejecuciones. No se probó contra el servicio real (sin credenciales); está probado con simulaciones del contrato. En el despacho se puede dirigir el documento a personas (`listado_id_usuarios_destinatarios`), pero la forma en que DocDigital las trata en la Oficina de Partes es **A VALIDAR** con Gobierno Digital.
- **Expedientes de oficio y partes:** las notificaciones por Casilla Única a partes sin solicitud usan el expediente como «folio» (contrato **A VALIDAR**). No hay registro verificado de poderes ni de representantes de personas jurídicas; la persona asistida no tiene acceso propio al sistema.
- **Formularios de trámites:** los campos son siempre visibles (no hay campos condicionales «mostrar si…»); los cálculos usan solo números, fechas, Sí/No y listas con valores numéricos; un número vacío vale 0 y una fecha vacía deja el cálculo sin resultado. Las respuestas se guardan como texto y valor tal como se enviaron: si el trámite cambia después, las solicitudes antiguas no se recalculan. La vista en vivo del navegador requiere JavaScript; sin él, el servidor calcula igualmente al enviar.

Asignación masiva y transiciones

- La asignación masiva procesa hasta 500 personas por operación y se probó con los datos de demostración, no con un directorio municipal completo.
- Las transiciones entre páginas (`@view-transition`) funcionan en navegadores que las soportan; en los demás se ve la carga normal. Los efectos se desactivan con «reducir movimiento» del sistema o de la barra de accesibilidad.

Permisos personalizados, Administrador Municipal y bandeja

- Conceder a una persona un permiso fuera de su rol le abre la **función** (pantalla y acción), pero las reglas de datos siguen siendo las de siempre (alcance por dirección, conflicto de interés, restringidos, firma que exige estar habilitado(a)). Quedan marcados «fuera de rol» en la bitácora. Esto puede debilitar la separación de funciones (por ejemplo, auditoría con permisos de operación): es una decisión de quien administra roles.
- «Administrador Municipal» tiene un conjunto por defecto definido por este equipo (como el Alcalde, sin cuatro permisos y sin delegaciones); el municipio debe confirmar ese conjunto y ajustarlo con permisos individuales.
- La separación «Por firmar / Por visar» muestra solo los documentos cuyo turno ya llegó a la persona; los que esperan a otro paso no aparecen hasta entonces.

Subrogancia

- La subrogancia da acceso a los expedientes que el titular tiene a cargo **al momento de consultar**: si el titular deja de tenerlos (otra persona pasa a ser responsable), el subrogante deja de verlos. Las acciones quedan registradas a nombre del subrogante; el expediente muestra el aviso, pero no hay un campo «en subrogancia de» en cada comentario.
- No traspasa firmas, visaciones ni expedientes restringidos, ni las solicitudes nuevas por asignar de la dirección del titular (esas siguen llegando a quienes pertenecen a la dirección). No avisa por correo al inicio ni al término.
- Probada con datos de demostración, no con un caso real del municipio.